

FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO

REDES DE COMPUTADORES E CIBERSEGURANÇA
PLANO DE GERENCIAMENTO DE RISCOS

Pedro Della Rosa Antônio

Pedro Dimitry Zyrianoff

Lucas Kenichi Soares Abe

Eduardo Chen Zou

Projeto Interdisciplinar - Smart Tennis Arena

Tech Tennis: Plano de Gerenciamento de Riscos

Data: 25/09/2026

Versão: 1.0

1. Introdução

Este relatório descreve como o gerenciamento de riscos e vulnerabilidades será estruturado e realizado para o Tech Tennis. O objetivo é identificar, analisar, planejar respostas e monitorar riscos e vulnerabilidades técnicas, de comunicação, de privacidade, de segurança física e operacionais, de modo a aumentar a probabilidade de sucesso do projeto e minimizar o impacto de eventos negativos, tanto durante o desenvolvimento em laboratório quanto no uso real do sistema — como em um treino ou em uma demonstração pública.

O relatório tem como foco a identificação e a documentação das vulnerabilidades do sistema e do código atualmente implementado, o firmware do Arduino Uno responsável por controlar os servomotores, o laser apontador, o buzzer e os LEDs, comandado via protocolo serial. O documento também antecipa riscos relacionados aos módulos ainda não implementados (comunicação Bluetooth via HC-05, dashboard web) ou parcialmente implementados (aplicativo Android, sua integração com a API e com os demais componentes do sistema, e visão computacional em Python), de forma que as respostas de mitigação possam ser planejadas e efetivamente implementadas na próxima fase do roadmap de segurança do produto.

2. Metodologia

A abordagem para o gerenciamento de riscos e vulnerabilidades neste projeto será a seguinte:

- **Identificação de Riscos e Vulnerabilidades:** realizada por meio de revisão do código-fonte do firmware Arduino, análise da documentação técnica do projeto (arquitetura, diagrama de conexões e protocolo de comandos), brainstorming com a equipe sobre os componentes ainda não implementados, e comparação com boas práticas conhecidas para sistemas embarcados e dispositivos IoT.
- **Análise de Riscos:** cada risco identificado é analisado qualitativamente para determinar sua probabilidade e impacto, segundo os critérios definidos nas Seções 6 e 7. Análise quantitativa realizada para os riscos de maior prioridade, quando aplicável.
- **Planejamento de Respostas:** para cada risco significativo é definida uma resposta planejada (prevenir, transferir, mitigar ou aceitar), a ser efetivamente implementada no código na segunda fase do roadmap de segurança, que exige relatório complementar com as mitigações aplicadas.
- **Monitoramento e Controle:** os riscos serão monitorados continuamente ao longo do projeto. O Registro de Riscos será atualizado a cada marco do cronograma do Tech Tennis.

3. Papéis e Responsabilidades

Papel	Responsabilidades no Gerenciamento de Riscos
Responsável Técnico (Hardware / Embarcados)	Revisar o firmware do Arduino e a arquitetura de hardware em busca de vulnerabilidades; liderar o processo de identificação de riscos técnicos; implementar as mitigações no código embarcado na Fase 2.
Equipe de Desenvolvimento (App Android, Dashboard, API)	Participar da identificação de riscos nos módulos de software ainda em desenvolvimento (autenticação, Bluetooth, Firebase); aplicar boas práticas de segurança (validação de entradas, criptografia, controle de acesso) conforme cada componente for implementado. Inclui a integração já implementada do aplicativo com a API via Wi-Fi/HTTP (Retrofit/OkHttp) e com o Firebase (Authentication e Firestore), e a análise contínua de novos riscos à medida que essa integração evolui.
Partes Interessadas (equipe do PI e futuros usuários)	Fornecer contexto sobre o uso pretendido do sistema (incluindo público infantil) para apoiar a identificação de riscos relacionados à segurança física e à privacidade dos dados.

4. Orçamento e Cronograma para Gerenciamento de Riscos

- **Orçamento:** por se tratar de um produto em fase de protótipo/MVP, sem orçamento financeiro formal dedicado, os recursos alocados ao gerenciamento de riscos correspondem ao tempo da equipe dedicado às atividades de segurança previstas no roadmap do produto, além de ferramentas gratuitas/open source (ex.: análise estática de código e, quando a API estiver disponível publicamente, OWASP ZAP).

- **Cronograma:**

- **Identificação Inicial de Riscos:** 15/09/2026 a 25/09/2026 (Entrega 1).
 - **Reuniões de Acompanhamento de Riscos:** semanais, alinhadas às reuniões gerais da equipe do produto Tech Tennis.
 - **Revisões do Plano de Gerenciamento de Riscos:** a cada marco do roadmap - Fase 1 (25/09/2026), Fase 2 (06/11/2026) e apresentação pública do produto (Semana FECAP de Tecnologia).
-

5. Categorias de Riscos

Os riscos e vulnerabilidades do Tech Tennis serão categorizados da seguinte forma, para facilitar a identificação e a análise:

Categoria	Descrição e exemplos no contexto do Tech Tennis
Técnicos — Hardware / Firmware	Riscos relacionados a componentes eletrônicos e ao código embarcado do Arduino: ausência de validação de entradas, ausência de mecanismo de parada segura, comportamento inesperado dos atuadores (servos, laser).
Técnicos — Comunicação / Rede	Riscos relacionados ao pareamento Bluetooth (HC-05), à comunicação Wi-Fi/HTTP da API e do dashboard já implementada, e à ausência de criptografia entre os componentes do sistema.
Aplicativo / Software	Riscos relacionados à autenticação, ao armazenamento de credenciais e à integração do aplicativo Android com o Firebase e com a API do Arduino/Flask.
Gerenciais / Organizacionais	Riscos relacionados à concentração de responsabilidades técnicas em poucos integrantes, à dependência de recebimento de componentes e ao cronograma do produto.
Privacidade e Conformidade (Externos)	Riscos relacionados à LGPD, especialmente por o sistema poder ser utilizado por crianças, e à futura integração com a plataforma Tech Tennis via API.
Segurança Física correlacionada à Cibersegurança	Riscos relacionados ao uso do laser apontador e dos servomotores, cujo controle remoto indevido ou malicioso poderia causar dano físico ao usuário.
Operacionais — Continuidade de Serviço (Uso em Produção / Eventos)	Riscos relacionados ao uso real do sistema fora do ambiente controlado de desenvolvimento — por exemplo, no dia de um treino ou de uma demonstração pública: falhas de câmeras, quedas de rede Wi-Fi, indisponibilidade da porta serial do Arduino, falta de energia, desgaste de componentes e dependência de um único notebook como servidor.

6. Definições de Probabilidade e Impacto

Probabilidade:

Nível	Descrição	Valor
Muito Alta	Quase certo de ocorrer	> 80%
Alta	Provável de ocorrer	61% – 80%
Média	Pode ocorrer	41% – 60%
Baixa	Improvável de ocorrer	21% – 40%
Muito Baixa	Muito improvável de ocorrer	< 20%

Impacto:

Nível	Descrição
Muito Alto	Aumento de mais de 20% no custo/esforço do projeto, ou comprometimento da segurança física do usuário ou de dados pessoais.
Alto	Aumento de 10% a 20% no custo/esforço do projeto, ou exposição relevante de dados/controlado não autorizado do sistema.
Médio	Aumento de 5% a 10% no custo/esforço do projeto.
Baixo	Aumento de 1% a 5% no custo/esforço do projeto.
Muito Baixo	Aumento de menos de 1% no custo/esforço do projeto.

7. Matriz de Probabilidade e Impacto

Esta matriz será utilizada para priorizar os riscos e vulnerabilidades identificados (sessão 8.):

Probabilidade \ Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo	Extremo
Alta	Baixo	Médio	Alto	Alto	Extremo
Média	Baixo	Médio	Médio	Alto	Alto
Baixa	Muito Baixo	Baixo	Baixo	Médio	Médio
Muito Baixa	Muito Baixo	Muito Baixo	Baixo	Baixo	Médio

Extremo / Alto: requerem atenção imediata e um plano de resposta detalhado.

Médio: devem ser monitorados de perto.

Baixo / Muito Baixo: serão monitorados como parte das atividades de rotina do projeto.

8. Registro de Riscos e Vulnerabilidades Identificados

O levantamento abaixo corresponde ao relatório de riscos e vulnerabilidades da primeira fase de avaliação de segurança do produto, elaborado a partir da revisão do firmware Arduino atualmente em funcionamento

(via Serial/USB), da análise da arquitetura documentada para os módulos ainda não implementados, do mapeamento de riscos operacionais que podem se manifestar durante o uso real do sistema — por exemplo, no dia de um treino ou de uma demonstração pública — e não apenas durante o desenvolvimento em laboratório, e da avaliação dos riscos associados à integração do aplicativo Android com os demais componentes do sistema, considerando tanto o que já foi efetivamente implementado (autenticação via Firebase, comunicação com a API via Wi-Fi/HTTP) quanto os riscos futuros dessa integração. As respostas planejadas para cada item deverão ser efetivamente implementadas e evidenciadas na Fase 2.

ID	Descrição do Risco / Vulnerabilidade	Categoria	Prob.	Impacto	Nível	Resposta Planejada (Entrega 2)
R01	Ausência de autenticação no protocolo de comandos (Serial/Bluetooth): o firmware aceita qualquer comando de um único caractere (A, D, W, S, L, E, B, R) recebido pela porta serial, sem verificar a identidade de quem envia. Quando o HC-05 for integrado, qualquer dispositivo pareado poderá controlar servos e laser sem autenticação adicional.	Técnico (Firmware / Comunicação)	Alta	Alto	Alto	Implementar handshake/token simples antes de aceitar comandos e restringir comandos sensíveis (laser) a sessões autenticadas.
R02	Configuração padrão do módulo Bluetooth HC-05: módulos HC-05 costumam vir com nome e PIN de pareamento padrão amplamente conhecidos, tornando o pareamento não autorizado plausível para qualquer pessoa próxima.	Comunicação / Rede	Alta	Alto	Alto	Alterar via comandos AT o nome do dispositivo e o PIN padrão do HC-05 antes da integração final.
R03	Ausência de criptografia robusta na comunicação Bluetooth Classic (perfil SPP), permitindo, em tese, interceptação ou repetição de comandos por um dispositivo dentro do alcance do rádio.	Comunicação / Rede	Média	Médio	Médio	Avaliar migração futura para BLE com pareamento seguro ou adicionar assinatura/validação simples nos comandos trocados.
R04	Ausência de validação e de limitação de taxa (rate limiting) na leitura serial: o loop() do Arduino lê continuamente caracteres sem limite de frequência, permitindo o envio excessivo de comandos e comportamento imprevisível dos atuadores.	Técnico (Firmware)	Baixa	Baixo	Baixo	Implementar intervalo mínimo entre comandos aceitos (debounce) e validação adicional de comandos inválidos.
R05	Ausência de mecanismo de parada segura (kill switch): o requisito RF22 do documento do projeto ainda não está implementado; não há comando de emergência que interrompa imediatamente servos e laser em caso de falha ou uso indevido.	Segurança Física / Técnico	Média	Muito Alto	Alto	Implementar comando prioritário de emergência que desliga o laser e trava os servos até reinício explícito, conforme RF22.
R06	Ausência de logs e auditoria de comandos: o firmware atual não registra comandos recebidos, origem ou horário, dificultando a identificação de uso indevido ou falhas (requisito RF23 ainda não atendido).	Técnico / Gerencial	Alta	Baixo	Médio	Registrar localmente (e futuramente via API) os comandos recebidos, respectivo timestamp e resultado.

R07	Segurança física do laser apontador (KY-008): se mal calibrado ou controlado indevidamente (ver R01/R02), o laser pode ser direcionado a uma posição que represente risco ocular ao praticante, especialmente considerando o público infantil citado no projeto.	Segurança Física	Baixa	Muito Alto	Médio	Limitar via software os ângulos possíveis dos servos a uma zona segura, adicionar proteção física/carcaça e verificar a classe de segurança do laser.
R08	Riscos antecipados da futura API/Dashboard (ainda não implementados): ausência prevista de HTTPS/TLS, exposição de tokens/segregos e falta de controle de acesso por perfil (RF01, RF17) caso não sejam considerados desde o início.	Aplicativo / Software (antecipado)	Média	Alto	Alto	Aplicar TLS obrigatório, gestão de segredos e autenticação/autorização por perfil desde o início do desenvolvimento da API.
R09	Proteção de dados de menores (LGPD): o sistema pode ser utilizado por crianças (RF11 e diretrizes de privacidade do projeto), que exigem minimização de dados e proteção reforçada de menores; ainda não há definição de quais dados serão coletados nem como serão protegidos.	Privacidade / Conformidade	Média	Muito Alto	Alto	Mapear os dados pessoais efetivamente coletados, aplicar minimização e consentimento adequado, e restringir o acesso a dados de menores.
R10	Dependência de fornecimento e concentração de responsabilidade técnica: o módulo HC-05 ainda não foi integrado e a responsabilidade pelo hardware está concentrada em um único integrante, representando risco organizacional para o cronograma.	Gerencial / Organizacional	Baixa	Médio	Baixo	Definir plano de contingência (uso temporário via Serial/USB, já funcional) e documentar o conhecimento técnico entre a equipe.
R11	Falha ou desconexão de uma câmera do sistema de visão computacional durante o uso (cabo USB solto, driver instável, câmera ocupada por outro processo), interrompendo a detecção de acertos pela visão. O sistema já possui um mecanismo de fallback por temporizador (acertos gerados automaticamente conforme o nível, quando a visão está inativa), o que reduz o impacto, mas retira a experiência real de detecção da bola durante a sessão.	Operacional	Média	Médio	Médio	Adicionar um alerta visível no aplicativo/dashboard indicando explicitamente quando o sistema está operando em modo de fallback (temporizador), e monitorar a reconexão automática da câmera quando possível.
R12	Bloqueio da porta do servidor Flask pelo firewall do sistema operacional do notebook (perfil de rede classificado como “Pública” por padrão no Windows), impedindo que o aplicativo alcance a API mesmo com o servidor em execução e o Arduino conectado, sem qualquer alerta claro para o operador no momento do evento.	Operacional	Média	Alto	Alto	Documentar e conferir, em checklist pré-evento, a regra de firewall liberando a porta do servidor para a rede local, e adicionar uma verificação de conectividade no início do aplicativo com mensagem de erro explícita.
R13	Indisponibilidade da porta serial do Arduino por conflito de software (ex.: monitor serial da IDE Arduino ou outro processo já conectado à porta COM), fazendo o backend operar em modo simulado — sem controlar de fato o hardware — sem que isso fique evidente para o operador durante uma sessão real.	Operacional	Alta	Alto	Alto	Manter e reforçar, na interface do aplicativo/dashboard, a indicação explícita do estado do Arduino (“conectado” vs. “simulado”), e incluir no checklist pré-evento o fechamento de qualquer programa que possa ocupar a porta serial.

R14	Alimentação elétrica insuficiente para os atuadores quando os dois servomotores e o laser operam simultaneamente a partir da porta USB do notebook, podendo causar movimentos fracos, imprecisos ou instáveis do laser apontador, especialmente nos níveis de dificuldade com movimento contínuo (Médio e Difícil) ou em sessões mais longas.	Operacional	Média	Médio	Médio	Utilizar fonte externa dedicada de 5V para os servomotores, com terra comum ao Arduino, isolando essa alimentação da porta USB do notebook.
R15	Ponto único de falha operacional: todo o sistema depende de um único notebook atuando simultaneamente como servidor da API, ponte serial para o Arduino e host da visão computacional. Um travamento, desligamento inesperado ou atualização automática do sistema operacional desse notebook durante um evento interrompe, ao mesmo tempo, o controle do hardware, a visão computacional e o atendimento ao aplicativo.	Operacional	Baixa	Alto	Médio	Desativar atualizações automáticas do sistema operacional durante eventos, manter um notebook reserva pré-configurado como contingência, e documentar o procedimento de reinício rápido do servidor.
R16	Comunicação entre o aplicativo Android e a API do servidor em texto puro (HTTP, sem TLS): comandos ao Arduino, posição do laser e dados de pontuação trafegam sem criptografia pela rede Wi-Fi local e podem, em tese, ser observados ou adulterados por outro dispositivo conectado à mesma rede.	Comunicação / Rede	Alta	Médio	Alto	Avaliar o uso de HTTPS com certificado autoassinado (fixado — pinned — no aplicativo) para a rede local, priorizando essa mudança antes de qualquer exposição do servidor além da rede local controlada.
R17	O endereço do servidor Flask é configurável diretamente na tela de conexão do aplicativo, sem validação de formato nem qualquer verificação da identidade do servidor de destino. Um erro de digitação ou uma ação mal-intencionada pode apontar o aplicativo para um servidor não autorizado, que simule respostas ou colete dados do dispositivo.	Aplicativo / Software	Baixa	Médio	Baixo	Validar o formato do endereço informado e exibir claramente, na tela, a identificação retornada pelo servidor (nome/versão) antes de confirmar a conexão.
R18	Variação das condições de iluminação do ambiente ao longo do dia (luz natural mudando de intensidade, sombras, iluminação artificial diferente da calibrada), reduzindo a taxa de detecção da bola pela visão computacional ou gerando falsos positivos na identificação de cor.	Aplicativo / Software (Visão Computacional)	Alta	Médio	Alto	Prever recalibração rápida dos parâmetros de cor (HSV) no início de cada sessão ou período do dia, e avaliar controle manual de exposição da câmera para reduzir a dependência da luz ambiente.
R19	Configuração incorreta das regras de segurança do Cloud Firestore, usado para autenticação (Firebase Authentication) e para o histórico de partidas dos usuários, poderia permitir que um usuário autenticado leia ou modifique o histórico de outro usuário, caso as regras não restrinjam corretamente o acesso por identificador do usuário autenticado.	Aplicativo / Software	Média	Alto	Alto	Revisar e testar explicitamente as regras de segurança do Firestore, restringindo leitura e escrita de cada histórico ao próprio usuário autenticado, e incluir esse teste no processo de validação antes de cada fase.

R20	A suíte de testes automatizados de integração do aplicativo (executada em um dispositivo real, pela rede Wi-Fi) aciona comandos reais no Arduino, incluindo a movimentação dos servomotores nos níveis Médio e Difícil. A execução acidental desses testes fora de um ambiente controlado, ou por alguém sem conhecimento do hardware conectado, pode causar movimentação inesperada dos atuadores.	Segurança Física	Baixa	Médio	Baixo	Manter a prática já adotada de nunca acionar o laser nesses testes automatizados, documentar claramente esse comportamento, e exigir confirmação explícita antes de rodar a suíte contra hardware real.
------------	---	------------------	-------	-------	--------------	---

9. Tolerância ao Risco das Partes Interessadas

A equipe do Tech Tennis possui baixa tolerância a riscos que possam comprometer a segurança física dos usuários por exemplo, exposição inadequada ao laser ou movimentação descontrolada dos servomotores e a riscos que envolvam a exposição de dados pessoais, especialmente de crianças e adolescentes, conforme a LGPD e os requisitos de privacidade definidos no documento do projeto (proteção reforçada de menores, coleta mínima e acesso restrito). Por outro lado, a equipe apresenta tolerância moderada a riscos que possam causar pequenos atrasos no cronograma do produto, já que o projeto está em fase de protótipo e alguns componentes estão em processo de aquisição e integração.

10. Formatos de Relatórios

- **Registro de Riscos:** mantido abaixo neste documento e, ao longo do projeto, em planilha compartilhada da equipe, com os campos ID, Descrição, Categoria, Probabilidade, Impacto, Nível de Risco, Resposta Planejada, Responsável e Status.

- **Relatório de Status dos Riscos:** será apresentado na Fase 2 do roadmap de segurança, evidenciando quais mitigações foram efetivamente implementadas no código, riscos residuais e novos riscos identificados durante a integração do Bluetooth, do aplicativo, da API e da visão computacional.

11. Acompanhamento

O processo de gerenciamento de riscos será revisado em cada marco do roadmap do produto Tech Tennis e a cada fase do planejamento envolvendo Redes de Computadores e Cibersegurança (Fase 1 em 25/09/2026 e Fase 2 em 06/11/2026), incorporando-se ao relatório de segurança consolidado da empresa. O Registro de Riscos é um documento vivo e será atualizado continuamente conforme novos componentes do sistema forem implementados.

